

Tech Request Form: AI RISK ASSESSMENT

Request	Date Request Submitted:	9/29/2025		
	Name of Requester:	Employee (fake)		
	Tool Name:	Github Copilot		
	Use Case:	AI Code assistant		
	Prepared By:	AI and Technology Manager		
	Date Completed:	9/30/2025		
Risk Assessment	Hazard	Initial Risk Level	Control	Residual Risk Level
	legal issues from copyright issues	H	check the license of code (impractical)	M
	deletion of important files	M	don't give copilot access to files (severly limits how useful copilot is)	L
	adding malware to code	H	Check every library and every code snippet, ensure you understand what it is doing (still risk of libraries looking fine but being fake)	M
	Poorly optimized code	L	Optimize code after using copilot, don't use it to optimize the code	L
	bad code that takes longer to fix than writing it from scratch to start	M	Only use good code (impractical, difficult to judge, likely to result in repeated prompts instead of rewrites)	L
	Overall Residual Risk Level (All controls implemented):	☐ Extremely High ☐ High ☒ Medium ☐ Low		
Approval	Overall Guidance:	This introduces risk from several attack surfaces which are difficult or impossible to mitigate while receiving the benefits of this tool.		
	Approved:	☐ Yes ☒ No		

Risk Assessment Matrix	Probability				
Severity	Frequent <i>Continous or In- evitable</i>	Likely <i>Numerous or Sev- eral</i>	Occasional <i>Sporadic</i>	Seldom <i>Infrequent</i>	Unlikely <i>Possible But Im- probable</i>
Catastrophic <i>unacceptable loss or damage, fail- ure</i>	EH	EH	H	H	M
Critical <i>severe damage, significant impact to capacity</i>	EH	H	H	M	L
Moderate <i>minor damage, noticeable affect on capacity</i>	H	M	M	L	L
Negligible <i>minimal damage, little to no impact on capacity</i>	M	L	L	L	L

<https://fossa.com/blog/analyzing-legal-implications-github-copilot/>
<https://thehackernews.com/2025/03/new-rules-file-backdoor-attack-lets.html>

Still working out several bugs

<https://copilot.github.com/trust/page/faq#security>

There are some measures to help reduce the risk of major security incidents, but given we're still hearing about them I don't think they fully address the issues

<https://docs.github.com/en/copilot/responsible-use>

^ could be helpful for additional guidance, includes limitations of the model

"Copilot generates code based on the context of the code being written, which can potentially expose sensitive information or vulnerabilities if not used carefully. You should be careful when using Copilot to generate code for security-sensitive applications and always review and test the generated code thoroughly."

"One of the limitations of Copilot is that it may generate code that appears to be valid but may not actually be semantically or syntactically correct or may not accurately reflect the intent of the developer. To mitigate the risk of inaccurate code, you should carefully review and test the generated code, particularly when dealing with critical or sensitive applications. You should also ensure that the generated code adheres to best practices and design patterns and fits within the overall architecture and style of the codebase."

"No, GitHub Copilot generates suggestions using probabilistic determination.

When thinking about intellectual property and open source issues, it is critical to understand how GitHub Copilot really works. The AI models that create Copilot ' s suggestions may be trained on public code, but do not contain any code. When they generate a suggestion, they are not " copying and pasting " from any codebase.

To generate a code suggestion, the Copilot extension begins by examining the code in your editor—focusing on the lines just before and after your cursor, but also information including other files open in your editor and the URLs of repositories or file paths to identify relevant context. That information is sent to Copilot ' s model, to make a probabilistic determination of what is likely to come next and generate suggestions.

To generate a suggestion for chat in the code editor, the Copilot extension creates a contextual prompt by combining your prompt with additional context including the code file open in your active document, your code selection, and general workspace information, such as frameworks, languages, and dependencies. That information is sent to Copilot ' s model, to make a probabilistic determination of what is likely to come next and generate suggestions.

To generate a suggestion for chat on GitHub.com, such as providing an answer to a question from your chat